

Visão Geral

Objetivo da Aula

Apresentar os principais pontos da construção de uma Política de Segurança da Informação (POSIC), que deve ser a base de um ambiente seguro e controlado em uma organização, e compreender que este é um documento formal e oficial, que estabelece diretrizes, princípios e regras para a segurança da informação.

Apresentação

Na era digital em constante evolução, a segurança da informação tornou-se uma prioridade central para organizações em todo o mundo. À medida que informações valiosas e sensíveis são criadas, armazenadas e compartilhadas eletronicamente, a necessidade de protegê-las contra ameaças cibernéticas e vazamento de dados é maior do que nunca. Esta aula é dedicada a compreender o coração de todo o esforço de segurança: a Política de Segurança da Informação.

Se podemos dizer que segurança da informação tem como objetivo montar uma fortaleza digital para proteger ativos, podemos dizer que POSIC (Política de Segurança da Informação e Comunicação) é o seu alicerce. Aqui, vamos introduzir este alicerce para a compreensão da importância da POSIC (ou PSI – Política de Segurança da Informação) e seu papel essencial na proteção das informações e ativos digitais de uma organização. Vamos começar nossa jornada na construção de um ambiente seguro de tecnologia da informação explorando esta base fundamental.

1. O que É POSIC?

A Política de Segurança da Informação e Comunicações (POSIC) fornece orientações de alto nível para definir as diretrizes e princípios gerais que devem ser seguidos para garantir a proteção adequada das informações. Vamos explicar em detalhes o que é a POSIC e como ela se distingue de outros componentes de segurança da informação, como normas, procedimentos e diretrizes técnicas.

Como um elemento central da segurança de informação de uma organização, a POSIC apresenta e define um conjunto formal de diretrizes, princípios e regras, que regulamentam o uso, o acesso e a proteção das informações na organização. Como política interna da empresa, a POSIC serve como uma declaração formal da organização quanto ao seu compromisso com a proteção das informações de seus ativos.

Este documento, produzido pelo esforço da equipe de segurança da informação, permeia tudo relativo à segurança da informação dentro daquela organização. Definindo a cultura de segurança, normas utilizadas, metas, objetivos, compromissos, planos de ações em casos específicos e em casos genéricos, conforme necessidade. É comum também listar leis relacionadas à organização e leis de segurança da informação para garantir a conformidade legal.

A decisão de publicar ou não a POSIC para acesso externo à organização depende dos requisitos específicos da organização e das suas considerações de segurança. Mesmo dentre as empresas que desejam (ou necessitam, por conformidades legais) publicar a sua POSIC, as práticas de publicação podem variar drasticamente.

Há casos de obrigações regulatórias ou contratuais, além de legais, que forçam a publicação da POSIC. Considere a LGPD ou a GDPR, por exemplo. Estes dois regulamentos, importantíssimos na Europa e no Brasil, exigem transparência e clareza ao público quanto à segurança da informação. Pode ser uma decisão estratégica também, formulando uma versão resumida ou de alto nível da POSIC para que partes interessadas, como potenciais investidores, clientes ou parceiros de negócio, possam ter uma compreensão básica das práticas de segurança aplicadas na organização. Em todos estes casos, as auditorias são importantes para garantir a lisura dos processos e ter certeza que tudo está dentro dos conformes; os auditores precisam ter acesso à POSIC para serem capazes de fazer seu trabalho.

Porém, publicar a POSIC parece contraintuitivo, pois se o público tem acesso aos processos de segurança da organização, atacantes e hackers em potencial também tem. Por isso, a decisão de publicar a POSIC deve considerar cuidadosamente a divulgação de informações sensíveis que possam ser úteis para atacantes. Elementos como detalhes específicos de configurações de segurança ou informações, que poderiam ser exploradas por invasores, devem ser tratados com cuidado.

Em muitos casos, a organização mantém a POSIC para partes interessadas, documento interno e auditores, mas ainda assim quer publicar algo para o público geral. Então, existe a possibilidade da criação de um portal ou página na web dedicada à segurança da informação na organização. Neste portal, costuma-se encontrar informações relevantes, como resumos, práticas gerais de segurança e diretrizes de contato.

Um esforço de toda organização, a decisão de publicar a POSIC para acesso fora da organização deve ser cuidadosamente avaliada em relação aos objetivos da organização, as obrigações regulatórias e, principalmente, o equilíbrio entre a transparência e a segurança. É aconselhável envolver a equipe de segurança da informação e, possivelmente, consultores jurídicos na tomada dessa decisão, especialmente se houver preocupações sobre a divulgação de informações sensíveis ou estratégicas.

Devido ao caráter público de organizações públicas, podemos encontrar diversos POSIC com simples buscas na internet. Vou utilizar a POSIC do Instituto Nacional de Câncer (INCA) como exemplo em alguns momentos nesta apostila. Você pode encontrar a POSIC do INCA neste link: https://www.inca.gov.br/sites/ufu.sti.inca.local/files//media/document//posic_-_politica_de_seguranca_da_informacao.pdf.

Figura 1: Capa POSIC INCA



Fonte: INCA. Disponível em: https://www.inca.gov.br/sites/ufu.sti.inca.local/files//media/document//posic_-_politica_de_seguranca_da_informacao.pdf. Acesso em: 1º fev. 2024.

2. Documento Formal

Vamos direto ao ponto. Além da definição do que é a POSIC, é necessário estabelecer do que é formado esse alicerce, destacando seu status como um documento oficial e formalmente estabelecido na organização. A aprovação da alta administração é um passo crítico, assegurando que a POSIC seja reconhecida e respeitada por todos os membros da equipe, incluindo os líderes da organização em questão.

Isso tudo é uma forma longa e complicada de garantir e afirmar que a POSIC não é apenas uma recomendação, mas um documento que foi criado e aprovado pela alta administração da empresa, conferindo-lhe legitimidade e autoridade. Dentro da empresa, o acesso à POSIC deve ser garantido a todos os membros que a seguem para que seja possível consultá-la e segui-la.

Considerando que, potencialmente, funcionários sem conhecimento de segurança da informação necessitam ler e compreender a POSIC, ao produzir este documento, são necessários alguns cuidados a mais, como definição de termos e conceitos.

2.1. Princípios, Regras e Diretrizes

A POSIC fornece diretrizes gerais, que descrevem como as informações devem ser tratadas, protegidas e utilizadas na organização. O comitê responsável pela produção deste documento deve regulamentar vários aspectos da segurança da informação, de acordo com as necessidades da organização. Esta regulamentação é feita com definição de políticas, normas e processos a serem implementados. Confira abaixo a lista de prioridades, segundo a POSIC do INCA.

- Classificação e Tratamento da Informação;
- Tratamento de Incidentes de Segurança da Informação;
- Gestão de Riscos;
- Gestão de Continuidade de Negócio;
- Auditoria, Monitoramento e Controle de Recursos Tecnológicos;
- Controle de Acesso Físico e Virtual;
- Uso de Serviços de Internet;
- Uso de Serviços de e-mail Institucional;
- Uso de Serviços de Sistemas Legados;
- Uso Institucional de Redes Sociais;
- Uso Institucional de Computação na Nuvem.

Esta lista pode ser observada na página 22 da POSIC do INCA, sob o capítulo de Diretrizes Gerais. Logo após a definição desta lista, a POSIC afirma que “Conforme necessidade e conveniência do INCA podem ser criados normativos sobre outros temas, que também farão parte desta política”, demonstrando o compromisso com a melhoria contínua, que deve sempre permear a segurança da informação, devido ao caráter de rápida evolução da tecnologia. No rodapé de todas as páginas deste documento, também é possível ver outra forma de compromisso com a melhoria contínua: a POSIC pede que se utilize a versão armazenada eletronicamente do documento, pois documentos impressos não são controlados e podem estar desatualizados.

Esta lista não é absoluta; cada empresa deve levar em consideração a sua realidade e suas necessidades. Outras empresas podem necessitar de gestão de dispositivos móveis, políticas de terceirização de serviços que lidam com os ativos. Cada organização pode adaptar suas diretrizes com base em seus requisitos específicos, regulamentações aplicáveis e ambiente de ameaças. Essas diretrizes são projetadas para proteger os ativos da informação da organização, garantindo os princípios de segurança da informação.

Após a definição de compromissos da POSIC, é necessário detalhar os processos, normas e políticas que são capazes de cumprir estes compromissos. Aqui, destaco novamente a importância de que o documento seja de alto nível para que detalhes sensíveis não sejam disponibilizados para atacantes em potencial.

Além das diretrizes, a POSIC, como documento de segurança da informação em uma organização, deve estabelecer e garantir os princípios fundamentais de segurança da informação, que são:

- **Confidencialidade:**
 - Garantir que as informações sejam acessíveis apenas para pessoas autorizadas.
- **Integridade:**
 - Garantir que as informações não sejam alteradas ou corrompidas de forma não autorizada.
- **Disponibilidade:**
 - Assegurar que as informações estejam disponíveis para as partes autorizadas quando necessário.

Não se limitando a diretrizes e princípios, a POSIC também aborda medidas práticas de segurança, que devem ser implementadas para proteger os ativos da organização. Isso pode incluir medidas técnicas, como firewalls, antivírus e criptografia, ou procedimentos operacionais, como políticas de backup, destruição segura de documentos, gestão de incidentes e gestão de acesso.

Por fim, é necessário o treinamento de conscientização sobre segurança, para garantir que os funcionários compreendam e cumpram as práticas e políticas de segurança. Regras específicas devem ser definidas e seguidas por todos os membros da organização. Isso pode incluir proibição de compartilhar senhas, necessidade de relatar incidentes de segurança e a conformidade com políticas de acesso.

2.2. Diferenças entre POSIC e outros Componentes

A distinção entre a POSIC e outros componentes da segurança da informação, como normas, procedimentos e diretrizes técnicas, é fundamental para uma gestão eficaz da segurança da informação. Cada um desses elementos desempenha um papel específico, e compreender suas diferenças é essencial para uma implementação bem-sucedida na segurança da informação.

Começando com a **POSIC**, ela é o mais alto nível de documentação na estrutura de segurança da informação. O alicerce da segurança, ela estabelece diretrizes gerais, princípios e regras que orientam a segurança da informação de uma organização. Um documento formal e oficial, aprovado pela alta administração, que define a abordagem, objetivos e cultura de segurança da informação. Porém, a POSIC não oferece instruções detalhadas sobre como implementar medidas de segurança específicas, mas orienta a organização sobre o que deve ser alcançado em termos de segurança da informação.

Normas são documentos mais detalhados, que fornecem especificações técnicas ou requisitos específicos para a implementação da segurança da informação. Elas são criadas com base nas diretrizes estabelecidas pela POSIC. As normas internas podem ser baseadas em padrões reconhecidos, regulamentações ou melhores práticas da indústria. Em alguns casos, a conformidade com normas internacionais é necessária. Elas descrevem como as tecnologias, processos e práticas de segurança devem ser aplicadas na organização. Um exemplo importante e relevante é a norma ISO 27001, que fornece um conjunto de requisitos para um sistema de gestão de segurança da informação, ou as normas de criptografia que descrevem algoritmos e protocolos específicos a serem seguidos.

Já os procedimentos são documentos que descrevem passo a passo como realizar tarefas específicas relacionadas à segurança da informação. São orientações práticas que explicam como implementar as medidas de segurança, em conformidade com as normas e a POSIC. Altamente operacionais, os procedimentos podem abranger uma ampla gama de atividades, desde o registro de incidentes de segurança até a configuração de firewalls, gerenciamento de patches e acesso a sistemas.

Diretrizes técnicas, por sua vez, são documentos que fornecem orientação específica sobre a configuração e o uso de tecnologia de segurança. Elas detalham como aplicar medidas de segurança em um nível técnico. Exemplos de diretrizes técnicas incluem as configurações recomendadas para firewalls, políticas de criptografia de dados ou configurações de segurança para servidores.

Cada componente desempenha um papel fundamental na criação de um ambiente de segurança da informação coeso e eficaz, com a POSIC estabelecendo a estrutura geral e as normas, procedimentos e diretrizes técnicas, oferecendo orientação detalhada e operacional. É importante que estes componentes trabalhem em conjunto para criar uma estrutura de segurança da informação robusta e bem definida na organização. Cada um deles desempenha um papel específico e complementar na proteção das informações e ativos da organização contra ameaças de segurança.

3. Objetivos e Benefícios da POSIC

A POSIC é um elemento essencial no âmbito da gestão de tecnologia da informação. Ela é um documento oficial e formalmente estabelecido, que desempenha um papel central na proteção de ativos críticos, na promoção da conformidade legal e regulatória, na promoção de uma cultura de segurança e na minimização de riscos de segurança da informação. Elaborada com vários objetivos em mente, a POSIC tem como função principal garantir os princípios da segurança da informação. Para isto, ela deve:

- **Estabelecer diretrizes:**
 - Definir as diretrizes é essencial para garantir que todos os membros da organização compreendam as expectativas em relação à SegInfo e sigam os procedimentos de forma consistente.
- **Promover conformidade legal:**
 - Auxilia a organização a cumprir regulamentações legais e requisitos regulatórios relacionados à segurança da informação;
 - Define como a organização deve abordar a conformidade.
- **Proteger ativos:**
 - O maior objetivo que permeia todos os aspectos de segurança da informação;
 - Inclui os três princípios fundamentais de segurança da informação:
 - Disponibilidade;
 - Integridade;
 - Confidencialidade.

- **Proteger a reputação:**

- A implementação bem-sucedida da POSIC ajuda a proteger a reputação da organização e a manter a confiança dos clientes;
- Considere um serviço de backup de fotos na nuvem; a reputação da organização nos olhos do cliente é um dos fatores mais importantes deste negócio.

- **Melhoria contínua:**

- Definir o compromisso da organização com a evolução da tecnologia.

- **Respostas a incidentes:**

- A POSIC define como a organização deve responder a incidentes de segurança, acelerando a identificação e a mitigação de ameaças e minimizando o impacto de violações de segurança.

Observando esta lista de objetivos, começa a ficar evidente que a implementação bem-sucedida da POSIC traz uma série de benefícios para a organização.

Alguns benefícios óbvios, como a proteção de ativos críticos e redução de riscos, mas outros mais sutis ao olhar leigo, como a eficiência operacional, redução de custos e prevenção de incidentes. A conformidade legal e regulatória abre novas portas para a organização, de acordo com seus objetivos de negócio. Por exemplo, uma instituição financeira necessita seguir regulamentações financeiras para lidar com outras instituições financeiras.

Se isso tudo ainda não for o suficiente para demonstrar a vantagem de uma POSIC, considere a vantagem competitiva que a demonstração de práticas de segurança sólida podem trazer à organização. Atraindo clientes, investidores e aumentando a confiança na organização como um todo.

Considerações Finais da Aula

A Política de Segurança da Informação (POSIC) é o alicerce central para estabelecer um ambiente seguro de tecnologia da informação em uma organização na era digital em constante evolução. Ela desempenha um papel crucial na proteção de ativos críticos, na promoção da conformidade legal, na construção de uma cultura de segurança e na minimização de riscos de segurança cibernética.

Ao compreender a importância da POSIC, fica claro que ela é o documento formal e oficial que estabelece diretrizes, princípios e regras para a segurança da informação. A aprovação pela alta administração confere à POSIC legitimidade e autoridade, garantindo que seja respeitada e seguida por todos os membros da organização.

A POSIC não apenas estabelece diretrizes gerais, mas também promove a conformidade legal e regulatória, protege ativos de informação, minimiza riscos, fortalece uma cultura de segurança, garante a disponibilidade das informações críticas e oferece diversos benefícios. Esses benefícios incluem a proteção de ativos, a redução de riscos, a conformidade legal, a preservação da reputação, a melhoria da eficiência operacional, a redução de custos, a preparação para incidentes, a promoção de uma cultura de segurança e uma vantagem competitiva.

Este documento oficial desempenha um papel central na gestão da segurança da informação e é fundamental para manter a confiança dos clientes, parceiros de negócios e partes interessadas. Ela fornece um alicerce sólido para a construção de um ambiente de tecnologia da informação seguro e é um guia essencial para a proteção de informações e ativos digitais em uma organização.

Portanto, a compreensão e implementação eficaz da POSIC são cruciais para a gestão eficaz da segurança da informação e para a criação de um ambiente onde informações sensíveis são protegidas contra ameaças internas e externas. Uma verdadeira peça fundamental no quebra-cabeça da segurança da informação em uma organização.

Material Complementar



Vídeo

Entenda o que é a Política de Segurança da Informação

2023, *Alerta Security Solution*.

Apresenta a Política de Segurança da Informação, que tem por objetivo possibilitar o gerenciamento da segurança em uma organização, estabelecendo regras e padrões para proteção da informação.

Disponível em: <https://www.youtube.com/watch?v=-KwdZjlw630>. Acesso em: 1º fev. 2024.

Referências

AGTIC. Nova Política de Segurança da Informação e Comunicação da UFPR. Universidade Federal do Paraná. **Agência de Tecnologia da Informação e Comunicação**, 2023. Disponível em: <https://www.agtic.ufpr.br/portal/blog/noticias/nova-politica-de-seguranca-da-informacao-e-comunicacao-da-ufpr/>. Acesso em: 1º ago. 2023.

MINISTÉRIO da Saúde. **Portaria n. 271**, de 27 de janeiro de 2017. Dispõe sobre a Política de Segurança da Informação e Comunicações do Ministério da Saúde (POSIC/MS). 2011. Disponível em: <https://datasus.saude.gov.br/wp-content/uploads/2019/12/portaria.pdf>. Acesso em: 1º ago. 2023.

OLIVEIRA, Carol. Política de Segurança da Informação e Comunicação PoSIC. **UNIRIO**, 2021. Disponível em: <http://www.unirio.br/dtic/politica-de-seguranca-da-informacao-e-comunicacao-posic>. Acesso em: 1º ago. 2023.